Healthcare IoT Network Security & Intrusion Detection System

David G. Moad | Rob Kuschel | Spring 2026

Abstract:

Healthcare Internet of Things devices face unprecedented security challenges that directly impact patient safety and hospital operations. This project demonstrates defense-in-depth security architecture through a fully functional hospital patient monitoring network and live attack scenario comparing vulnerable and hardened system configurations with identical hardware.

Our infrastructure consists of nine Ubuntu Server virtual machines providing hospital IT services (database management, MQTT messaging, HL7 FHIR transformation, SIEM, identity management, and secrets management) and seven Raspberry Pi devices. Five Pi units generate realistic cardiac telemetry representing distinct patient profiles, while two units serve as attack demonstration controllers. The system processes 100 sensor readings per second through an HL7 FHIR-compliant pipeline, maintaining over 53 million database records with zero data loss.

The attack demonstration compares identical pressure sensor systems with dramatically different outcomes. The vulnerable system implements a Flask HTTP API with no authentication or input validation. When an attacker sends spoofed "0.0 PSI" readings at 10 Hz, the system blindly accepts the data, causing catastrophic vessel failure within 20 seconds with no security logging. The secure system validates all network data against local I2C sensor measurements, detecting the mismatch and rejecting all attacks while maintaining safe operation. Every attack is logged to Wazuh SIEM with complete forensic details, and all traffic is captured by Suricata IDS and visualized in real-time Grafana dashboards.

The Problem:

Healthcare IoT Security Crisis:

- 82% of healthcare organizations hit by ransomware in past year
- Average breach cost: $10.9 million (highest of any industry)
- 400+ U.S. hospitals forced to divert ambulances during ransomware incidents
- 465,000 pacemakers recalled due to cybersecurity vulnerabilities

Patient Safety Impact:

- Real-time monitoring systems are life-critical infrastructure
- Device failure or data manipulation can directly threaten patient safety
- Compromised cardiac monitors could mask emergencies or trigger false alarms
- Infusion pumps could be manipulated to deliver incorrect medication dosages
- Stakes far higher than data breaches in other sectors

Why Traditional Security Fails:

- Embedded firmware cannot be easily updated so vulnerabilities stay unpatched
- Inadequate or absent network segmentation allows lateral movement
- Missing input validation creates trivial attack vectors

Process:

Production-Grade Hospital Infrastructure:

- 9 Ubuntu Server VMs running on enterprise hardware
  - PostgreSQL database, MQTT broker, Node-RED automation
  - Grafana visualization, Mirth Connect HL7 engine, HAPI FHIR server
  - Wazuh SIEM, Keycloak identity management, HashiCorp Vault secrets
- 7 Raspberry Pi devices
- 100 sensor readings per second through HL7 FHIR-compliant pipeline
- Cardiac data flows: MQTT→ Node-RED → PostgreSQL
- Rate-Limited stream to Mirth Connect → HL7 FHIR transformation → HAPI server
- 53+ Million heartrate records in active tables
- 87 GB of historical data in archive tables

Network Segmentation:

- VLAN 30 (10.30.0.0/24): Secure hospital infrastructure
- VLAN 2 (192.168.50.0/24): Isolated attack laboratory

Demonstration Methodology:

- Two identical pressure sensor systems, same hardware:
  - Raspberry Pi 5 controllers
  - DATAQ analog pressure sensors
  - ADS1115 ADC converters, BSS138 level shifters
  - Sequent relay HATs, solenoid valves, air pumps
  - Identical pressure vessels
- Only difference: Security implementation
  - Vulnerable: Accepts sensor data via unauthenticated Flask API, no input validation
  - Secure: Validates all incoming sensor readings against local I2C readings

Analysis:

Input Validation is Fundamental:

- Vulnerable system's unconditional trust of network data = trivia attack vectors
- No sophisticated techniques needed
- No privilege escalation required
- No software vulnerability exploitation
- Attacker sends HTTP POST with false sensor values
- System accepts without question
- Mirrors real-world IoT compromises

Defense-In-Depth Approach:

- Effective IoT security requires multiple complementary layers
- Network segmentation: Limits attack surface exposure
- Intrusion detection: Provides visibility into attack attempts
- SIEM monitoring: Enables forensic analysis and incident response
- Identity management: Controls access to administrative functions
- Physical sensor validation: creates hardware-rooted chain of trust
- Approach ensures protection even if individual control is bypassed
- Secrets management: Protects credentials from exposure
- Transport security: Prevents man-in-the-middle attacks

Results:

Attack Testing Methodology:

- 150 attack attempts against each system using attack_spoof.py in dual-target mode
- Simultaneous spoofed pressure readings to both systems at 10 Hz per target
- False claim: 0.0 PSI when actual pressure measured is 25 PSI

Vulnerable System (192.168.50.100)

- Accepted all 150 attacks (100% success rate)
- Zero detections logged
- Catastrophic vessel failure
- Continuous pump activation based on false readings
- Real pressure exceeded safe limits
- "Invisible attack" scenario: No indication to admin until physical damage done

Secure System (10.30.0.25)

- Rejected all 150 attacks (0% success rate)
- 100% detection and logging
- Each rejection logged with complete forensic info
  - Source IP: 192.168.50.191
  - Claimed pressure: 0.0 PSI
  - Actual Measured Pressure: 25.0 PSI
  - Sensor mismatch: 25.0 PSI (exceeds 1.0 PSI threshold)
  - Timestamp and rejection reason
- Maintained normal operation throughout attack
- Zero downtime or service degradation

Attack Outcomes:

Intrusion Detection Pipeline:

- Suricata IDS on dedicated monitoring laptop (192.168.50.191)
- Traffic mirrored from switch port 15
- Security events generated for each HTTP POST with spoofed data
- Events forwarded via Filebeat → Elasticsearch (10.30.0.60)
- Real-time visualization in Grafana dashboards

IDS Dashboard Visibility:

- Attack frequency: 10 requests/second per target
- Source IP: Attacker system (192.168.50.191)
- Destination IP: Both vulnerable and secure targets
- Event types: HTTP POST to /sensor endpoint
- Temporal attack patterns

Performance Outcomes:

Infrastructure Stability During Attacks:

- Cardiac monitoring pipeline: Sustained 100 readings/second with zero data loss
- PostgreSQL: 53+ million records in active tables, 87 GB in historical archives
- HL7 FHIR pipeline: 1 observation/second through Mirth → HAPI FHIR server
- Network latency: No degradation during attack periods
- Database query performance: Stable throughout
- Dashboard update rates: No impact
- Security monitoring infrastructure imposes minimal performance overhead

References:

1. HIMSS Analytics. (2024). Healthcare Cybersecurity Study: Ransomware Impact Assessment and Mitigation Strategies.
2. IBM Security. (2024). Cost of a Data Breach Report 2024: Healthcare Sector Analysis.
3. Ponemon Institute. (2024). Medical IoT Security in Connected Healthcare Environments.
4. HL7 International. (2024). FHIR R4 Specification for Observation Resources.
5. MITRE ATT&CK. (2024). ICS Attack Framework: Healthcare Sector Tactics and Techniques.

Advisor: Rob Kuschel, CTH
Affiliation: GE Aerospace

David G. Moad
Computer Engineering